

PENETRATION TESTING SERVICES

Request for Proposal (RFP) - Briefing Document

For: Nam-mic Payment Solutions (Pty) Ltd

Date: 15 August 2025

Document Classification: Confidential

1. EXECUTIVE SUMMARY

Nam-mic Payment Solutions (Pty) Ltd seeks qualified cybersecurity firms to conduct a comprehensive penetration testing assessment of our payment infrastructure in compliance with the Bank of Namibia's Payment System Determination (PSD-12) requirements.

2. REGULATORY BACKGROUND

2.1 Bank of Namibia PSD-12 Compliance Requirements

As a licensed entity within the National Payment System (NPS), Nam-mic Payment Solutions is subject to the **Payment System Management Act, 2003** and specifically the **Operational and Cybersecurity Standards within the National Payment System (PSD-12)** determination.

Key Regulatory Requirements:

- **Section 11.3:** Mandatory penetration testing every three years for critical systems
- **Section 11.11:** Testing of response, resumption, and recovery plans with recovery point objective of at least 5 minutes
- **Section 13:** Compliance with risk indicators including 99.9% uptime for critical systems and 2-hour recovery time objective

2.2 Regulatory Scope

PSD-12 applies to all:

- Payment Service Providers (PSPs)
- Retail Payment Systems (electronic funds transfers, payment cards, e-money)
- Entities licensed within the National Payment System
- FinTech entities under the Bank's regulatory framework

3. CURRENT SECURITY POSTURE

3.1 Previous Assessment Overview

Our last penetration test was conducted in October 2019.



4. SCOPE OF WORK

4.1 In-Scope Assets and Systems

Based on our current infrastructure and previous assessments, the following systems require testing:

External-Facing Infrastructure:

- IP Range: 41.190.84.130 - 41.190.84.158
- Web applications and portals
- Payment processing endpoints
- API gateways
- Email servers
- FTP/SFTP services

Critical Payment Systems:

- Transaction processing systems
- Authentication mechanisms
- Database systems
- Backup and recovery systems
- Network infrastructure components

4.2 Testing Methodology Requirements

Grey Box Testing Approach:

- Limited internal network knowledge provided
- Focus on external attack vectors
- Web application security testing

Excluded from Scope:

- Physical security assessments
- Social engineering attacks against staff
- Denial of Service (DoS) attacks on production systems
- Any testing that may impact live payment processing

4.3 Compliance-Specific Testing Areas

This document contains confidential information. Distribution is restricted to invited vendors only.

In accordance with PSD-12 requirements:



1. **Vulnerability Management (Section 11)**

- Identification of critical business functions
- Assessment of protective controls
- Detection capability evaluation
- Response and recovery testing

2. **Safety Standards (Section 12)**

- Encryption/tokenization verification
- Two-factor authentication validation
- Payment transaction security

5. DELIVERABLES AND OUTCOMES

5.1 Required Reporting

Executive Summary Report:

- Risk assessment aligned with PSD-12 risk indicators
- Compliance gap analysis
- Priority remediation roadmap

Technical Report:

- Detailed vulnerability findings
- Exploitation evidence (where safe)
- Remediation recommendations
- Compliance mapping to PSD-12 requirements

5.2 Risk Classification Framework

Align findings with the following risk levels:

- **Critical:** Immediate threat to payment system integrity
- **High:** Significant risk to confidentiality/availability
- **Medium:** Moderate risk requiring attention
- **Low:** Minor issues for future consideration

6. TESTING CONSTRAINTS AND REQUIREMENTS

6.1 Operational Constraints

- **Testing Window:** Outside business hours (18:00-06:00 WAT)
- **Production Impact:** Zero tolerance for payment system disruption
- **Notification:** 48-hour advance notice for all testing activities
- **Emergency Stop:** Immediate cessation upon request



6.2 Regulatory Documentation

- Maintain detailed logs of all testing activities
- Evidence preservation for regulatory review
- Chain of custody documentation
- Compliance with data protection requirements

6.3 Industry Standards Compliance

Testing must align with:

- OWASP Top 10 methodology
- NIST Cybersecurity Framework
- ISO 27001 security controls
- PCI DSS requirements (where applicable)

7. VENDOR QUALIFICATIONS

7.1 Required Certifications

Team Qualifications:

- CISSP, CISM, or equivalent security certifications
- CEH, OSCP, or similar penetration testing credentials
- PCI QSA certification (preferred)

7.2 Experience Requirements

- Minimum 5 years financial services penetration testing
- Previous payment system assessments

8. PROPOSAL REQUIREMENTS

8.1 Technical Proposal

- Detailed methodology approach
- Testing tools and techniques

- Team composition and CVs
- Risk mitigation strategies
- Compliance reporting approach



8.2 Commercial Proposal

- Fixed price quotation
- Payment schedule
- Additional services pricing
- Emergency response rates

8.3 References

- Minimum 3 services references
- Recent penetration testing case studies
- Regulatory compliance testimonials

9. EVALUATION CRITERIA

Technical Capability (40%):

Experience (30%):

Commercial (20%):

Compliance (10%):

A handwritten signature in black ink, appearing to read 'Melissa Gamses', is positioned above a horizontal line.

Melissa Gamses (Ms.)

Chief Executive Officer

Nam-Mic Payment Solutions (Pty) Ltd